Luca Danisi **31-3-2026**

```
Null session + Arp
     Poisoning
```

- Cosa vuol dire Null session?

E' una vulnerbilità di Windows che permette di autenticarsi senza credenziali, e permette di enumerare informazioni sensibili come , lista utenti e policy.

- Quali sistemi sono vulnerabili a Null Session, e sono ancora in commercio?

Windows NT, Windows 2000, Windows XP, Windows Server 2003.

- Come si mitiga/risolve la vulnerabilità Null Session?

Richiedere autenticazione , Bloccare le porte SMB , Aggiornare il sistema.

- Come funziona l ARP Poisoning?

L'attaccante invia finti pacchetti ARP nella rete, associando il proprio MAC address all'IP del gateway (e viceversa alla vittima). Così entrambi aggiornano le loro ARP table con il MAC dell'attaccante, che si posiziona in mezzo al traffico , come "man in the middle" .

- Quali sistemi sono vulnerabili ad ARP Poisoning?

Qualsiasi dispositivo in una rete locale che usa ARP è potenzialmente vulnerabile.

- Come si mitiga, rileva o annulla l'ARP Poisoning?

Mitigare → Arp Statico.

Rilevare → Wireshark.

Annullare → Isolare il dispositivo dalla rete.

1 - Obiettivo :

Dimostrare come funziona un attacco ARP Poisoning utilizzando Ettercap in un ambiente di laboratorio controllato. L'attacco ha lo scopo di posizionarsi come Man-in-the-Middle tra una macchina vittima (Windows) e il gateway (pfSense), intercettando il traffico di rete non cifrato e catturando credenziali in chiaro.

🧪 **Laboratorio**

🐉 **Kali Linux**: Attaccante
💀 **Windows 10 pro** : macchina target
Pfsense : Gateway

Entrambe le macchine sono su rete interna.

2 - Strumenti utilizzati

- **Ettercap 0.8.4** — strumento per attacchi Man-in-the-Middle e ARP Poisoning
- **Wireshark** — analizzatore di pacchetti per verificare il traffico ARP
- **Kali Linux** — macchina attaccante (192.168.50.100)
- **Windows 10** — macchina vittima (192.168.50.102)
- **pfSense** — gateway/router di rete (192.168.50.1)
- **VirtualBox** — ambiente di virtualizzazione per il laboratorio

3 - Risultati

1. **ARP Poisoning riuscito** — la tabella ARP di Windows mostrava il gateway (192.168.50.1) con il MAC address di Kali (08-00-27-79-33-ba), confermando che Kali si era posizionata come Man-in-the-Middle.
2. **Credenziali intercettate** — Ettercap ha catturato in chiaro le credenziali inserite su un sito HTTP:
    - **URL:** http://demo.testfire.net/login.jsp
    - **Username:** admin
    - **Password:** admin

3. **Wireshark ha rilevato l'attacco** — i pacchetti ARP fasulli erano chiaramente visibili, con il messaggio "duplicate use of 192.168.50.102 detected!", confermando l'avvelenamento della rete.

2 - Problemi incontrati

1. **DNS mal configurato** — Windows aveva il DNS impostato su Kali (192.168.50.100) da un esercizio precedente. Kali non fa da DNS server, quindi nessun sito era raggiungibile. Risolto impostando il DNS su **8.8.8.8**.
2. **Sito di test non disponibile** — il sito originale dell'esercizio (testphp.vulnweb.com) era offline. Sostituito con **demo.testfire.net**, un altro sito HTTP vulnerabile adatto al test.
3. **IP Forwarding disabilitato** — Kali intercettava i pacchetti ma non li riforwardava, bloccando la navigazione della vittima. Risolto abilitando il forwarding con:

   ```
   echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
   ```

4. **Assenza di gateway reale** — inizialmente la rete interna non aveva un gateway, rendendo l'attacco parziale. Risolto avviando **pfSense** come router della rete.

5 - Conclusioni

L'attacco ARP Poisoning è stato eseguito con successo in ambiente controllato. I risultati dimostrano quanto sia semplice per un attaccante posizionarsi come **Man-in-the-Middle** in una rete locale e intercettare traffico non cifrato.

Il punto critico emerso è che **HTTP non offre nessuna protezione** — le credenziali viaggiano in chiaro e chiunque nella rete può leggerle. Basterebbe usare **HTTPS** per rendere i dati intercettati illeggibili.

Wireshark ha inoltre dimostrato che questo tipo di attacco **è rilevabile** — i pacchetti ARP fasulli lasciano tracce evidenti, e un SOC analyst esperto potrebbe individuarlo monitorando anomalie nella ARP table o con tool dedicati come ARPwatch.

Svolgimento Tecnico

1. **Verifica collegamento**

   Verifichiamo che le nostre VM , Attaccante (**Kali Linux – 192.168.50.100**) e target (**Windows 10 pro – 192.168.50.102**) siano in grado di comunicare tra di loro. Test effettuato tramite PING.

2. **Avvio scansione con Ettercap**

   Dal terminale di Kali Linux lanciamo il programma con il comando "**`sudo ettercap -G`**", successivamente avviamo la scansione degli host rilevabili sulla rete.

3. **Identificazione target & Arp Spoofing**

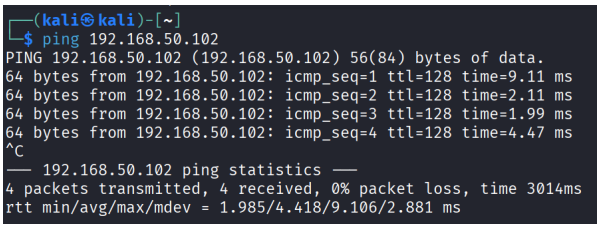
   Dopo la scansione e l identificazione dei nostri target (Windows IP 192.168.50.102- MAC 08:00:27:16:CC:21, Pfsense 192.168.50.1-MAC 08:00:27:16:CC:21), avviamo l' Arp poisoning (sniff remore connections).

4. **Arp poisoning vulnerabilità esposta**

   Apriamo il nostro terminale su Windows e con il comando **"arp -a",** notando subito che Kali e Pfsense hanno lo stesso MAC address, in questo modo tutto il traffico passa per il MAC address dell attaccante. Verifichiamo la vulnerabilità aprendo sul browser di windows una pagina web HTTP dov è richiesto l accesso con credenziali: wireshark ci mostrerà l anomalia dell associazione dello steso MAC address a 2 differenti IP, e Ettercap ci mostrerà in chiaro le credenziali inserite all interno della pagina web.

Screenshot

Figure 1 – Verifica collegamento macchine con Ping.



```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.102
PING 192.168.50.102 (192.168.50.102) 56(84) bytes of data.
64 bytes from 192.168.50.102: icmp_seq=1 ttl=128 time=9.11 ms
64 bytes from 192.168.50.102: icmp_seq=2 ttl=128 time=2.11 ms
64 bytes from 192.168.50.102: icmp_seq=3 ttl=128 time=1.99 ms
64 bytes from 192.168.50.102: icmp_seq=4 ttl=128 time=4.47 ms
^C
--- 192.168.50.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3014ms
rtt min/avg/max/mdev = 1.985/4.418/9.106/2.881 ms
```

Figura 2 – Avvio Ettercap su Kali

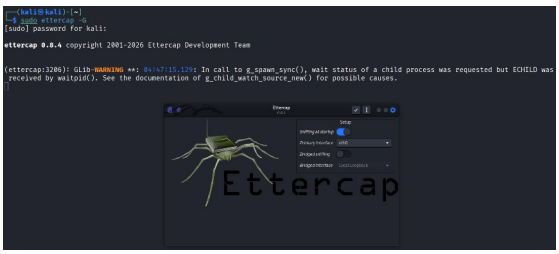
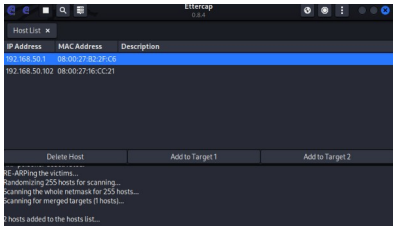
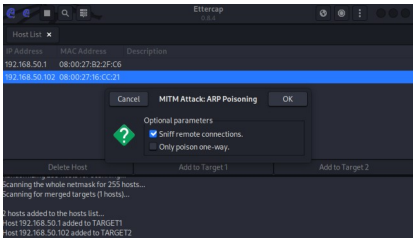


Figura 3 – Scan host sulla rete & scelta target




```
2 hosts added to the hosts list...
Host 192.168.50.1 added to TARGET1
Host 192.168.50.102 added to TARGET2
```

Figura 4 – ARP poisoning & Verifica



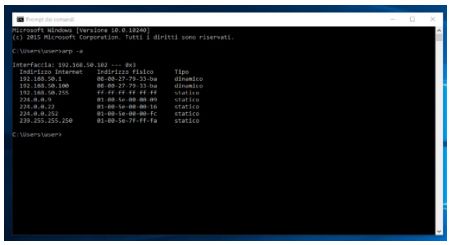
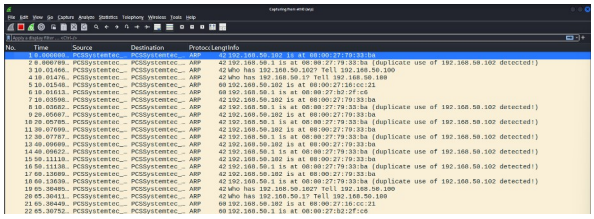


Figura 5 – Vulnerabiltà esposta da Wireshark

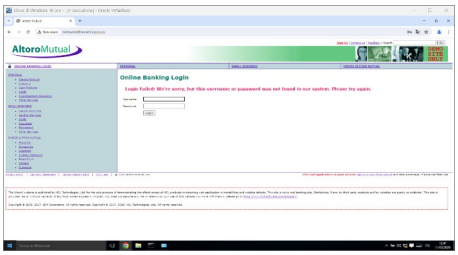


```
[Duplicate IP address detected for 192.168.50.1 (08:00:27:79:33:ba) - also in use by 08:00:27:b2:2f:c6 (frame 7)]
[Duplicate IP address detected for 192.168.50.102 (08:00:27:16:cc:21) - also in use by 08:00:27:79:33:ba (frame 7)]
```

Figura 6 – Vulnerabiltà esposta Ettercap

```
GROUP 1 : 192.168.50.1 08:00:27:B2:2F:C6

GROUP 2 : 192.168.50.102 08:00:27:16:CC:21
HTTP : 65.61.137.117:80 -> USER: admin  PASS:  INFO: http://demo.testfire.net/login.jsp
CONTENT: uid=admin&passw=admin&btnSubmit=Login
```



End